

17 JUN 2016

US\$ 60M

The DAO

— "O hack que dividiu o Ethereum ao meio"

REENTRANCY · CRITICAL

3,6 milhões de ETH drenados em uma única transação

O QUE ACONTECEU

The DAO era o maior fundo de investimento descentralizado da história em 2016 — arrecadou **US\$ 150 milhões** em ETH em apenas 28 dias.

A ideia era simples: qualquer pessoa podia propor projetos e os investidores votavam. Quem discordasse podia sair via a função **splitDAO**, recebendo seu ETH de volta.

Um atacante descobriu que a função **fazia a transferência antes de zerar o saldo**. Com um contrato malicioso no fallback, ele **reentrava** na função e sacava repetidamente.

O Ethereum fez um **hard fork** para reverter o roubo — criando o Ethereum Classic (ETC) como a chain original.

CONTRATO VULNERÁVEL

```
do investidor uint
    payable { dao.splitDAO(proposalID); // reentra! }
    fallback() external
```

Lição

Atualize o estado **antes** de qualquer chamada externa: [Checks](#) → [Effects](#) → [Interactions](#)

COMO O ATAQUE FUNCIONOU

PASSO 1

Atacante deposita ETH no DAO

**PASSO 2**

Chama `splitDAO()` para sacar

**PASSO 3**

DAO envia ETH → `call.value(balance())`

**PASSO 4**

`fallback()` do atacante é acionado

**PASSO 5**

`fallback()` chama `splitDAO()` novamente!

**PASSO 6**

Saldo ainda não foi zerado → `saca de novo`



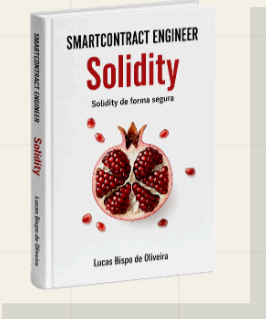
LOOP Repete até drenar o contrato

VERIFIQUE NA BLOCKCHAIN

Transação do Ataque
etherscan.io/tx/0x0ec3f2...3790b

Contrato The DAO
etherscan.io/address/0xBB9bc...9413

Dark DAO (atacante)
etherscan.io/address/0x304a...3490



Solbook — Smartcontract Engineer

Aprenda a se proteger contra reentrância e mais 23 tipos de ataque